

# 站點漏洞修復暨解決方案探討

以App Scan掃描軟件為基礎（V1.0）

Peak

FIH IT

# 目錄

- 高風險漏洞6類（立即修復）
- 中風險漏洞12類（必須修復）
- 低風險漏洞19類（建議修復）
- 參考類風險漏洞2類（有條件修復）
- 討論&問答



# 部分漏洞及解決

共39類

# SQL脚本注入

## 漏洞/問題描述

- 攻擊者利用該漏洞，訪問未經授權的數據，甚至修改/刪除相關數據。

## 原因分析

- 攻擊者可以構建拼接SQL語句，從而實現對數據庫的增刪改查操作。

select * from dbo.users where userno='{p1}' and pwd='{p2}'

p2="abc' or 0=0 --"

## 解決方案

- ✓ 根據不同的SQL版本過濾特殊字符
- ✓ 使用參數化的存儲過程@p1
- ✓ 使用新版架構，基本都有規避SQL注入的問題

# SSL2、SSL3、TLS1.0、TLS1.1開啟漏洞

## 漏洞/問題描述

- 服務器端開啓了不安全的SSL2、SSL3、TLS1.0、TLS1.1 協議。

## 原因分析

- SSL2、SSL3、TLS1.0、TLS1.1協議使用了脆弱的加密方式和算法，攻擊者可以透過暴力破解等方式取得機密資料，存在重大安全漏洞，容易受到降級攻擊的嚴重影響。
- 目前TLS1.2被認為相對安全，還有後續版本TLS1.3。

## 解決方案

✓ 在服務器端關閉不安全的通訊協議




IIS協議配置器.exe

A、IIS站點可網上下載 IIS Crypto工具；
B、Nginx可修改相關配置文件實現。

# 發現不存在的鏈接

## 漏洞/問題描述

- 找到外部站點的鏈接，但無法解析該鏈接。

## 原因分析

- Web應用程序包含了不存在域的鏈接，攻擊者可以利用該場景，通過注冊不存在的域名來啓動釣魚攻擊，用戶可能會瀏覽該惡意站點。

## 解決方案

- ✓ 除去不必要、不存在的鏈接，定期檢查外部鏈接的有效性。

# 反射/存儲型跨網站腳本攻擊（XSS攻擊）

## 漏洞/問題描述

- 跨站腳本攻擊（XSS），指攻擊者通過篡改網頁，嵌入惡意腳本程序，在用戶瀏覽網頁時，控制用戶瀏覽器進行惡意操作的一種攻擊方式。

## 原因分析

- 反射型XSS攻擊主要將惡意代碼透過URL的參數進行傳遞，從而實現攻擊。
- 存儲型XSS攻擊將惡意代碼上傳至服務器端，用戶訪問時惡意代碼都將會被執行，具有隱蔽性。

xxx.aspx?x=<script>alert(123)</script>

## 解決方案

- ✓ 不要相信用戶端輸入的任何東西！
- ✓ 不要相信用戶端輸入的任何東西！
- ✓ 不要相信用戶端輸入的任何東西！
- ✓ 可以透過工具或手動進行惡意代碼檢查
- ✓ 盡可能不要用JavaScript做跳轉

# API成批分配問題

## 漏洞/問題描述

- API參數中接收了不必要的參數，或者參數爲null。

## 原因分析

- 公開的API接口，接受了不必要的參數。
- 攻擊者可以使用這種方法來更新或覆蓋開發人員從未打算公開的敏感對象的屬性。

```
public class User
{   public string Code { get; set ;}
   public string Password { get; set; } }
JSON:{ “Code” : ”ABC”, ”Password”: ”***”, ”IP”: ”10.”}
```

## 解決方案

- ✓ 設置嚴格JSON轉換規則 MissingMemberHandling.Error &NullValueHandling.Ignore
- ✓ 使用數字簽名，檢驗簽名是否正確？
- ✓ 手動自行過濾不必要的參數，參數不匹配要報錯

# 整數溢出

## 漏洞/問題描述

- 接收了非預期的數據類型，可能暴露內部信息。

## 原因分析

- 接收了非預期的數據類型，如預期一個Guid類型的參數，但當參數值傳99999999時，未給出錯誤。

## 解決方案

- ✓ 檢查所輸入的參數，使其與要求匹配，否則給出錯誤提示。

# 應用程序報錯（Application error messages）

## 漏洞/問題描述

- 應用程序報錯，出現Application或Web應用程序錯誤等信息。即所謂的頁面報紅問題。

## 原因分析

- 應用程序錯誤而未做響應處理；
- 應用程序只處理了正常的情況，未處理例外情況。

## 解決方案

- ✓ 盡量處理可能的异常情況，并給出提示
- ✓ 設置自定義的統一錯誤頁面，可以解決未知的一些錯誤。

在web.config中<system.web>段設置如下片段

```
<customErrors mode="RemoteOnly"
defaultRedirect="Error.htm" />
```

# .Net程序報錯（.Net error messages）

## 漏洞/問題描述

- 應用程序報錯，出現Application或Web應用程序錯誤等信息。即所謂的頁面報紅問題。攻擊者可以從中獲得更多詳細信息。

## 原因分析

- 應用程序錯誤而未做響應處理；
- 應用程序只處理了正常的情況，未處理例外情況。

## 解決方案

- ✓ 盡量處理可能的异常情況，并給出提示
- ✓ 設置自定義的統一錯誤頁面，可以解決未知的一些錯誤。

在web.config中<system.web>段設置如下片段

```
<customErrors mode="RemoteOnly"
defaultRedirect="Error.htm" />
```

# 未加密的__VIEWSTATE參數

## 漏洞/問題描述

- 使用未加密的VIEWSTATE參數，提示Unencrypted __VIEWSTATE parameter等。
- 已解密的 __VIEWSTATE 參數

## 原因分析

- .Net服務器控件繼承了ViewState屬性，以隱藏變量的方式發送給客戶端。
- 默認情況下不開啟加密選項，攻擊者可以解密這些數據。

## 解決方案

- ✓ 配置將ViewState加密處理
- ✓ 配置不通加密machineKey。

在web.config中<system.web>段設置如下片段

```
<pages controlRenderingCompatibilityVersion="4.0" enableViewStateMac="true" viewStateEncryptionMode="Always" clientIDMode="AutoID" />

<machineKey validationKey="64bitdata" decryptionKey="32bitdata" validation="SHA1" decryption="AES" />
```

注：machineKey可以在Workflow→工具箱中生成。

# 易受攻擊的組件

## 漏洞/問題描述

- 使用第三方jQuery等組件時，版本過低。

## 原因分析

- 第三方組件版本過低未升級。
- 攻擊者可能使用低版本已知的漏洞進行攻擊和破壞活動。

## 解決方案

- ✓ 升級到最新版本
- ✓ 注意升級後系統的測試，特別是跨越多個版本的情況
- ✓ 針對jQuery有個兼容插件jQuery Migrate可以使用
- ✓ 如果處理困難，可以拆分登錄頁和內部頁面。

# 具有不安全、不正確或缺少 SameSite 屬性的 Cookie

## 漏洞/問題描述

- 具有不安全、不正確或缺少 SameSite 屬性的 Cookie，。

## 原因分析

- 具有不安全、不正確或缺少 SameSite 屬性的敏感 Cookie。
- 如果沒有額外的保護措施（如CSRF令牌），攻擊者可能會擴展到跨站點請求偽造攻擊。
- .Net Framework某些Cookie沒有放在請求頭裡，也可能會報錯。
- Set-Cookie：User=ABC; Path=/; SameSite=Lax; HttpOnly; Secure

## 解決方案

- ✓ SameSite通常情況下至少要設置為Lax，並確保包含HttpOnly和Secure屬性。
- ✓ 對於.Net組件對接賬號中心的程序，可以將認證方式設置爲授權碼模式。
- ✓ 混合模式采用Post請求，設置為Lax將無法獲取xxx.OpenIdConnect.Nonce.xxx和xxx.Correlation.xxx類似的Cookie.

代碼中配置：

options.ResponseType = “code”;

options.ResponseMode = “query”;

賬號中心後台模式配置：

authorization_code

# SHA1弱密碼套件問題

## 漏洞/問題描述

- 檢測到SHA1密碼套件。

## 原因分析

- SHA-1、MD5等已經被證明存在安全隱患，容易受到碰撞攻擊。

## 解決方案

- ✓ 參考TLS1.1關閉方式。
- ✓ 除如下紅框部分，建議都關閉。
- ✓ 提供外部接口的系統需留意，外部接口可能會有問題，外部接口服務器需做相同動作。



# 弱密碼套件-ROBOT攻擊：服務器支持易受攻擊的套件

## 漏洞/問題描述

- 偵測到支援 TLS-RSA 金鑰交換的密碼組合。

## 原因分析

- 本過低具有 TLS 實作缺陷的 Web 伺服器或應用程式伺服器可能容易遭到 ROBOT 攻擊。

## 解決方案

- ✓ 參考TLS1.1關閉方式。
- ✓ 除如下紅框部分，建議都關閉。
- ✓ 提供外部接口的系統需留意，外部接口可能會有問題，外部接口服務器需做相同動作。



# 檢測到弱密碼：并非所有密碼套件均支持完全前向保密

## 漏洞/問題描述

- Web 伺服器或應用程式伺服器，低強度密碼：并非所有密碼組合都支援完全秘密轉遞。

## 原因分析

- 低强度的加密秘鑰容易遭受攻擊

TLS_RSA_WITH_AES_128_CBC_SHA TLS 1.2

TLS_RSA_WITH_AES_256_CBC_SHA TLS 1.2

TLS_RSA_WITH_AES_128_CBC_SHA256 TLS 1.2

TLS_RSA_WITH_AES_256_CBC_SHA256 TLS 1.2

TLS_RSA_WITH_AES_128_GCM_SHA256 TLS 1.2

TLS_RSA_WITH_AES_256_GCM_SHA384 TLS 1.2

## 解決方案

- ✓ 參考TLS1.1關閉方式。
- ✓ 除如下紅框部分，建議都關閉。
- ✓ 提供外部接口的系統需留意，外部接口可能會有問題，外部接口服務器需做相同動作。



# 低强度的密碼組合：不支援 AEAD

## 漏洞/問題描述

- 低强度的密碼組合有被可能竊取或操作客戶階段作業和 Cookie，并可能用來假冒合法的使用者。

## 原因分析

- 低强度的加密秘鑰容易遭受攻擊

TLS_AES_128_GCM_SHA256

TLS_AES_256_GCM_SHA384

TLS_AES_128_CCM_SHA256

TLS_AES_128_CCM_8_SHA256

……

## 解決方案

- ✓ 參考TLS1.1關閉方式。
- ✓ 除如下紅框部分，建議都關閉。
- ✓ 提供外部接口的系統需留意，外部接口可能會有問題，外部接口服務器需做相同動作。



# 未實施加密

## 漏洞/問題描述

- 使用http協議成功訪問到相關資源。

## 原因分析

- 站點使用不安全的通道交換信息。
- 使用了http協議加載了信息，簡言之80端口也可以訪問站點。

## 解決方案

- ✓ 關閉80等端口，只允許使用域名和SSL證書訪問站點。
- ✓ 使用URL Rewrite實現http跳轉https也可以解決此問題，但除非必要，不推薦使用。

# 通過框架釣魚/連接注入（便於跨站請求偽造）

## 漏洞/問題描述

- 參數中接受了<iframe>或<img>等標籤，從而嵌入廣告或惡意代碼。

## 原因分析

- 沒有對參數進行必要的檢查，接收html標籤。




## 解決方案

- ✓ 檢查輸入的參數，非必要不接受標籤<xxx>格式的參數。確有必要需特別留意。

# 不安全的第三方鏈接 (target="_blank")

## 漏洞/問題描述

- 發現第三方鏈接 (target="_blank")，但不包含rel屬性。

## 原因分析

- 攻擊者可能获得对链接页面（本站點）的有限访問如：window.opener，然后它可以使用它来更改链接页面的 URL 通过Window.opener.location。可能利用新標簽頁篡改原始頁面URL。

## 解決方案

- ✓ 在打開外部鏈接的a標籤中增加rel="noopener noreferrer"屬性，禁止子頁面通過window.opener訪問父頁面的內容。

# ASP.NET開啓了調試（debugging enabled）

## 漏洞/問題描述

- ASP.NET開啓了調試模式 debugging enabled

## 原因分析

- 開啓了調試模式，容易暴漏站點等相關信息，使攻擊者利用這些信息進行非法活動。

## 解決方案

✓ 生產環境下不要啟用debug

Web.config中<system.web>段改為如下配置

```
<compilation debug="false"
targetFramework="4.6.1">
```

注意：開發環境下此值需要設置為true，才能進行代碼調試，更新web.config文件時需要留意。

# ASP.NET版本暴露（version disclosure）

## 漏洞/問題描述

- ASP.NET版本暴露version disclosure

## 原因分析

- .Net版本信息對於用戶不重要，但容易使攻擊者利用這些信息進行進一步試探或非法活動。

## 解決方案

✓ 禁用版本信息信息

Web.config中<system.web>段改為如下配置

```
<httpRuntime enableVersionHeader="false" />
```

# 點擊劫持（Clickjacking: X-Frame-Options頭）

## 漏洞/問題描述

- 發現了點擊劫持弱點

## 原因分析

- 未正確設置X-Frame-Options頭一般情況下設置為SAMEORIGIN即可。
- 攻擊者可以利用這個漏洞來隱藏你的網站然後在用戶看不見的地方顯示他們自己的內容，以此來欺騙用戶。

## 解決方案

- ✓ 正確配置X-Frame-Options
- ✓ 正確配置CSP的frame-ancestors指令

Web.config中<system.webServer>添加如下配置

```
<httpProtocol>
 <customHeaders>
  <add name="X-Frame-Options" value="SAMEORIGIN" />
 </customHeaders>
</httpProtocol>
```

# HttpOnly未設置（Cookies without HttpOnly flag set）

## 漏洞/問題描述

- 發現不帶HttpOnly的Cookie

## 原因分析

- Cookie中沒有設置HttpOnly標志，這意味著這些cookie可以被客戶端腳本訪問，從而增加了跨站腳本攻擊（XSS）的風險
- HttpOnly標志的作用是限制cookie僅通過HTTP請求傳輸，防止客戶端腳本訪問這些cookie。如果cookie沒有設置HttpOnly標志，惡意腳本可以通過文檔對象模型（DOM）訪問這些cookie，進而進行XSS攻擊。

## 解決方案

- ✓ 正確配置HttpOnly標記
- ✓ Set-Cookie中增加HttpOnly標記

Web.config中<system.web>段添加如下配置

```
<httpCookies httpOnlyCookies="true" />
```

注意：不要衝突！

# HSTS策略未實現（HSTS not implemented）

## 漏洞/問題描述

- 頭部沒有發現Strict-Transport-Security屬性或這是不正確

## 原因分析

- 出現“HTTP Strict Transport Security (HSTS) not implemented”這樣的警告，意味著瀏覽器沒有實施HSTS策略，即使網站聲明它應該只通過HTTPS訪問，瀏覽器仍然允許用戶通過HTTP訪問。

## 解決方案

- ✓ 確保包含“Strict-Transport-Security”頭，值通常可以設置為max-age=31536000;
- ✓ 確保站點是https站點
- ✓ 正確配置httpCookies

Web.config中<system.web>段添加如下配置

```
<httpCookies requireSSL="true" />
```

# 可能的敏感文件（Possible sensitive files）

## 漏洞/問題描述

- 發現可能的敏感文件如test.html/test.aspx/admin等等

## 原因分析

- 敏感文件可能洩露相關機密信息。比如某些Test頁面，未經授權就可以操作數據庫等等。

## 解決方案

- ✓ 生產環境請刪除這些敏感文件
- ✓ 改名也可以修復此漏洞，但不推薦

# 發現可高速緩存的SSL頁面

## 漏洞/問題描述

- 發現可高速緩存的SSL頁面

## 原因分析

- 缺省情況下，大部分 Web 瀏覽器都配置成會在使用期間高速緩存用戶的頁面。 這表示也會高速緩存 SSL 頁面。不建議讓 Web 瀏覽器保存任何 SSL 信息，因爲當有漏洞存在時，可能會危及這個信息。

## 解決方案

- ✓ 根據需要設置緩存指令
- ✓ 建議如下設置：

Web.config中<system.webServer>添加如下配置

```
<httpProtocol>
 <customHeaders>
  <add name="Cache-Control" value="no-store" />
  <add name="Pragma" value="no-cache" />
 </customHeaders>
</httpProtocol>
```

# “Content-Security-Policy”頭缺失或相應策略不安全

## 漏洞/問題描述

- 缺失CSP標頭
- CSP中缺少“Style-Src”/“Object-Src”/“Script-Src”或“Default-src”指令或相應指令不安全。

## 原因分析

- 未正確配置CSP
- 詳細CSP介紹請參考朱經理《CSP應用策略教程》

## 解決方案

- ✓ 程序中不要使用行內樣式和行內JS等代碼
- ✓ 將樣式/JS以文件的方式引用
- ✓ 根據需要正確配置CSP，特別注意不要包含unsafe-inline和unsafe-eval指令

配置範例，參考後續章節

# “X-Content-Type-Options”頭缺失或不安全

## 漏洞/問題描述

- X-Content-Type-Options”頭或者不安全

## 原因分析

- 網站可能缺少一個安全相關的HTTP響應頭，或者該頭的值不是足够安全或合適的。
- "X-Content-Type-Options"頭是一個用來幫助防止MIME類型混淆的安全功能，它可以防止瀏覽器嘗試執行非預期的內容類型。

## 解決方案

- ✓ 正確配置X-Content-Type-Options頭

Web.config中<system.webServer>添加如下配置

```
<httpProtocol>
 <customHeaders>
 <add name="X-Content-Type-Options" value="nosniff" />
 </customHeaders>
</httpProtocol>
```

# 在應用程式中發現不必要的 Http 回應頭"X-Powered-By"

## 漏洞/問題描述

- 發現了X-Powered-By請求頭。

## 原因分析

- X-Powered-By請求頭指示了系統基本架構情況，對用戶來說是不必要的。這可能幫助攻擊者查找已知的漏洞和安全問題。如果服務器運行過時的軟件或框架版本，攻擊者可能會利用這些已知漏洞進行攻擊。

## 解決方案

- ✓ 從自定義請求頭中移除X-Powered-By頭
- ✓ 利用URL Rewrite插件移除

Web.config中<system.webServer>添加如下配置

```
<httpProtocol>
 <customHeaders>
 <remove name="X-Powered-By" />
 </customHeaders>
</httpProtocol>
```

# 查詢中接受的主體參數

## 漏洞/問題描述

- 在Web請求時發現了主題參數。

## 原因分析

- .Net請求時為未對參數進行匹配
- GET和POST請求接受了相同的參數，如“__VIEWSTATEGENERATOR”、“__VIEWSTATEENCRYPTED”等等參數。

## 解決方案

- ✓ 匹配相關參數，如GET請求時不接受“__VIEWSTATEGENERATOR”、“__VIEWSTATEENCRYPTED”等等參數

# 檢測到隱藏目錄

## 漏洞/問題描述

- 檢測到隱藏的目錄，如/files、/images、/doc、/upload、/Temp等等。

## 原因分析

- 請求目錄時報403沒有權限錯誤。表示存在該目錄，可能會被攻擊者進行破壞活動。

## 解決方案

- ✓ 首先不要將目錄配置爲可瀏覽模式
- ✓ 在Web.config中配置403轉404錯誤。

Web.config中<system.webServer>添加如下配置

```
<httpErrors>
    <remove statusCode="403" subStatusCode="-1" />
    <error statusCode="403"
prefixLanguageFilePath="%SystemDrive%\inetpub\custerr"
path="404.htm" responseMode="File" />
  </httpErrors>
```

# 加密會話（SSL）Cookie 中缺少 Secure 屬性

## 漏洞/問題描述

- 返回的Cookie信息中未包含Secure屬性。

## 原因分析

- 缺少Secure會導致在非HTTPS環境下傳輸時，Cookie內容可能被竊取，從而引發信息泄露和身份盜竊等安全問題。爲了解決這個問題，需要在Cookie中設置Secure屬性。
- 如果是http協議則不傳遞信息。

## 解決方案

- ✓ Cookie中增加Secure屬性即可。

# 永久 Cookie 包含敏感的會話資訊

## 漏洞/問題描述

- 返回的Cookie信息中包含過期時間等敏感信息。

## 原因分析

- 跨站請求僞造令牌“XSRF-TOKEN”中包含過期時間信息。
- “XSRF-TOKEN”不應被設置為Cookie而是應該被設置為類似Session，當網頁關閉後則會被銷毀。

## 解決方案

✓ 跨站請求僞造令牌Cookie中不要包含Expires屬性。

# 發現社會保險號模式

## 漏洞/問題描述

- 返回的html代碼中包含類似社保號、身份證號、銀行卡號等信息。

## 原因分析

- 返回的信息中包含了機密信息，特別是對于未登錄之前不應該包含這些信息。

## 解決方案

- ✓ 刪除敏感信息。
- ✓ 對信息進行脫敏處理。

# 發現X-Aspnet-Version頭

## 漏洞/問題描述

- Header中發現X-Aspnet-Version頭。

## 原因分析

- X-Aspnet-Version暴漏系統開發版本，攻擊者可以有針對性的進行嘗試和攻擊。

## 解決方案

- ✓ 去掉X-Aspnet-Version標頭
- ✓ 使用URL Rewrite複寫請求頭

Web.config中<system.web>段添加如下配置

```
<httpRuntime targetFramework="4.6.1"
enableVersionHeader="false" />
```

# 發現Server頭

## 漏洞/問題描述

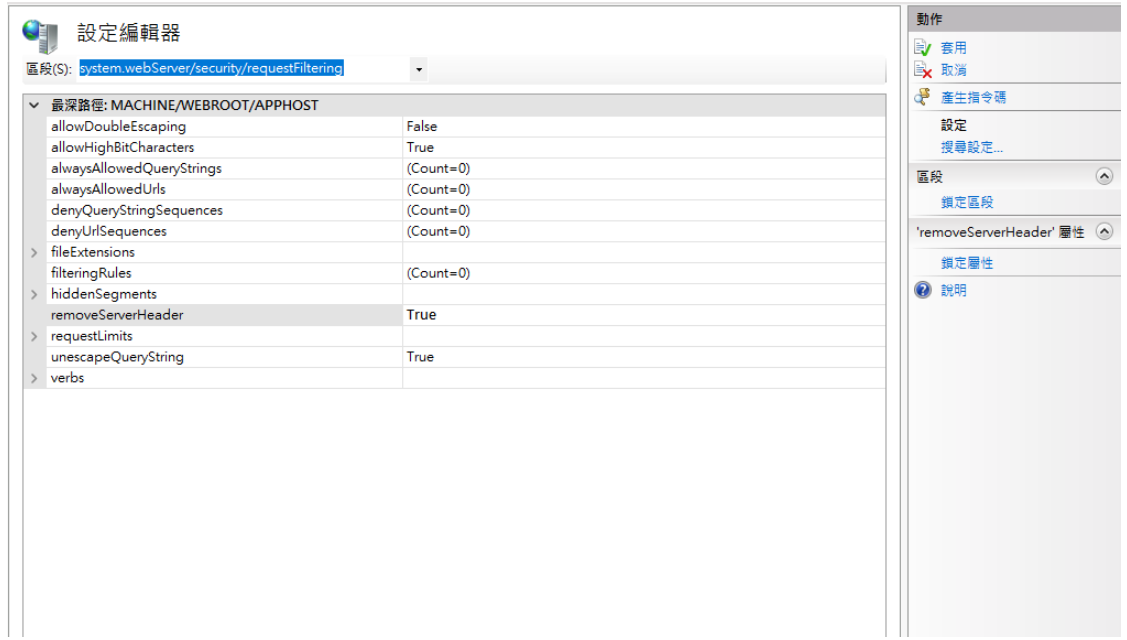
- Header中發現Server頭。

## 原因分析

- Server暴漏系統配置，攻擊者可以有針對性的進行嘗試和攻擊。
- Server可能是類似IIS 10.0、Nginx 1.24之類的。

## 解決方案

- ✓ 在服務器層面刪除Server頭
- ✓ IIS web.config中使用<remove name="Server" />中直接清除可能無效。
- ✓ 使用URL Rewrite複寫請求頭。



# 發現電子郵件地址模式

## 漏洞/問題描述

- 返回的html代碼中包含了郵箱地址。

## 原因分析

- 郵箱地址暴露可能會，收到垃圾或廣告郵件。

## 解決方案

- ✓ 如非必要請勿公開郵箱等敏感信息。

# 應用程序報錯

## 漏洞/問題描述

- 傳遞異常的參數如參數中傳遞%00、%27、\"、、'等等，收到了异常信息。

## 原因分析

- 未對輸入進行嚴格檢查和限制，返回500錯誤。
- 攻擊者可以從響應中獲取有用的信息，利用該信息找出應用程序的弱點。

## 解決方案

- ✓ 建議處理檢查輸入參數，不接受非法參數，參數非法直接報通用錯誤。

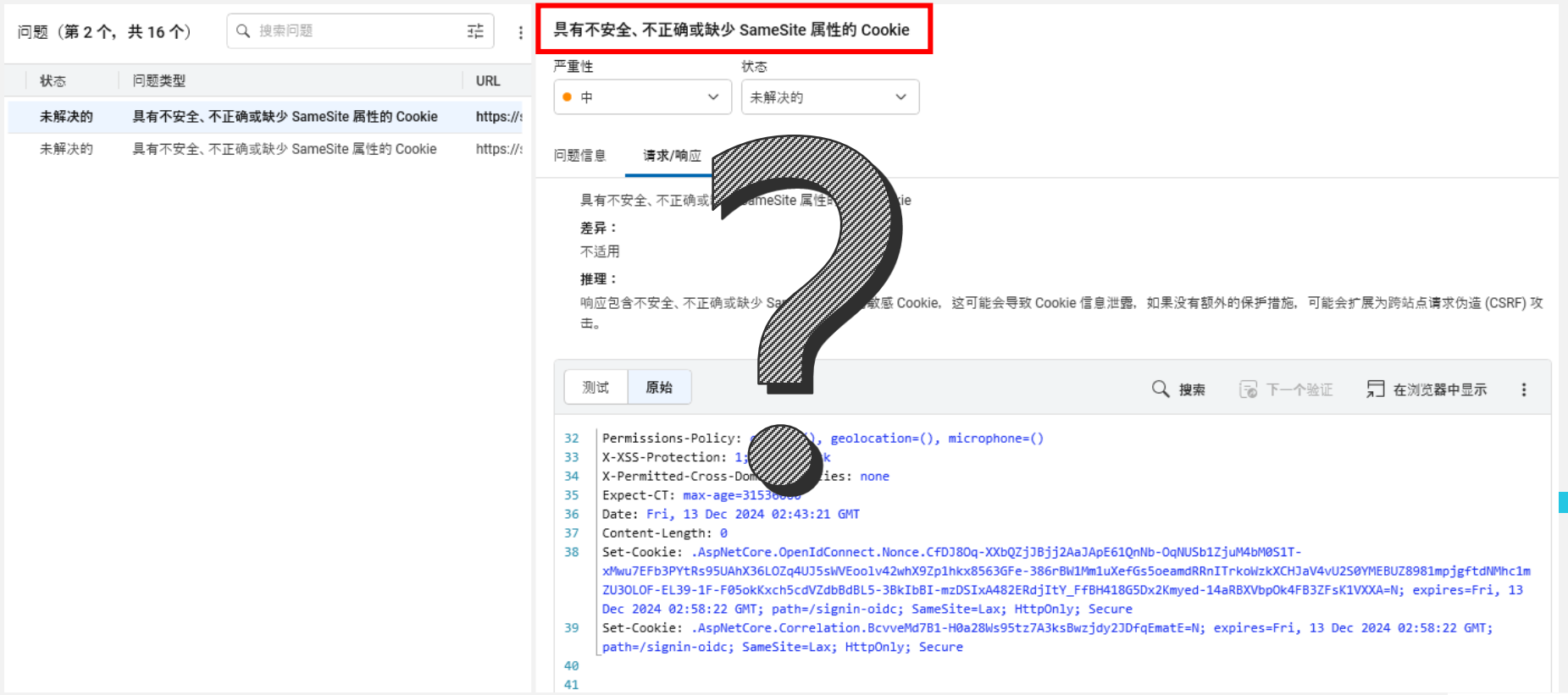


# 討論&問答

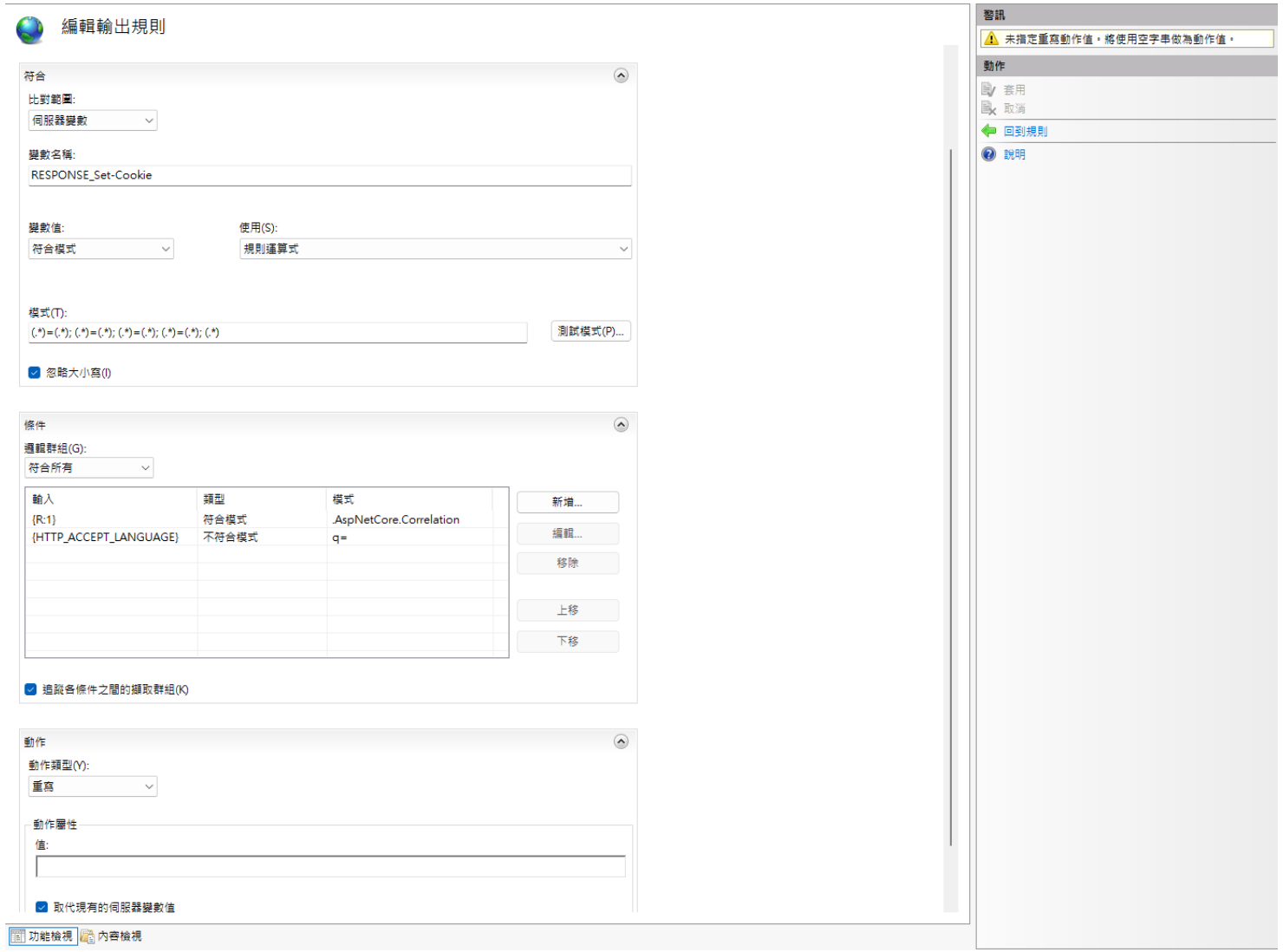
## SameSite和附件上傳問題

# SameSite問題

在.Net Core接入賬號中心時，會有類似.AspNetCore.OpenIdConnect.Nonce.xxx和.AspNetCore.Correlation.xxx兩個Cookie，但AppScan掃描時會報如下錯誤：



# 沒有辦法的辦法？？？


編輯輸出規則
符合
比對範圍:
伺服器變數
變數名稱:
RESPONSE_Set-Cookie
變數值:
符合模式
使用(S):
規則運算式
模式(T):
(.*)=(.*); (.*)=(.*); (.*)=(.*); (.*)=(.*); (.*)
測試模式(P)...
忽略大小寫(I)
條件
邏輯群組(G):
符合所有
輸入
類型
模式
{R:1}
符合模式
.AspNetCore.Correlation
{HTTP_ACCEPT_LANGUAGE}
不符合模式
q=
新增...
編輯...
移除
上移
下移
追蹤各條件之間的擷取群組(K)
動作
動作類型(Y):
重寫
動作屬性
值:
取代現有的伺服器變數值
功能檢視
內容檢視
警訊
未指定重寫動作值。將使用空字串做為動作值。
動作
套用
取消
回到規則
說明

# 附件上傳問題

附件上傳是攻擊者常用的一種攻擊方式，攻擊者把類似Webshell的惡意文件上傳到此服務器。

危險類型文件包括".aspx"、".js"、".php"、".asp"、".htm"、".html""、".vbs"、".dll"和".exe"等等。

對於圖片類型，也可能會包含惡意代碼，建議對公開的上傳文件功能做圖片過濾。



# CSP參考範例（1）

```
default-src 'none'; script-src 'nonce-eFpECIsKYuQzA7UAkHzaUErEIQV8Hk09' 'sha256-orD0/VhH8hLqrLxKHD/HUEMdwqX6/0ve7c5hspX5VJ8=' 'sha256-bBR11t3xOeLLkccI6Pn1hYbkHCL+JE4CLkgBydaPSE0=' 'strict-dynamic'; img-src 'self' *.fihmb.com *.fihtdc.com https://icivetmedia.foxconn.com data:; style-src 'self' 'sha256-u+OupXgfekP+x/f6rMdoEAspPCYUtca912isERnoEjY='; child-src 'self'; font-src 'self'; frame-ancestors 'self' https://*.fihmb.com https://*.efihmb.com https://*.fihtdc.com https://zp.foxconn.com https://*.mobiledrivetech.com https://*.bharatfih.com; frame-src 'self' https://*.fihmb.com https://*.efihmb.com https://*.fihtdc.com https://zp.foxconn.com https://*.mobiledrivetech.com https://*.bharatfih.com; form-action 'self' https://*.fihmb.com https://*.efihmb.com https://*.fihtdc.com https://zp.foxconn.com https://*.mobiledrivetech.com https://*.bharatfih.com https://localhost:* http://localhost:*; connect-src 'self'; object-src 'none'; base-uri 'self';
```



# CSP参考範例（２）

```
default-src 'none';script-src 'nonce-7djwelibbksle36' 'strict-dynamic';img-src 'self' data:;style-src 'self';child-src 'self';font-src 'self';frame-ancestors 'self';frame-src 'self';form-action 'self';connect-src 'self';object-src 'none';base-uri 'self';
```



# CSP參考範例（3）

```
default-src 'none'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://*.foxconn.com
https://*.fihtdc.com https://*.mobiledrivetech.com https://*.fihmb.com https://*.bharafih.com; style-
src 'self' 'unsafe-inline' https://*.foxconn.com https://*.fihtdc.com https://*.mobiledrivetech.com
https://*.fihmb.com https://*.bharafih.com; object-src 'self' https://*.foxconn.com https://*.fihtdc.com
https://*.mobiledrivetech.com https://*.fihmb.com https://*.bharafih.com; img-src 'self' data: blob:
https://*.foxconn.com https://*.fihtdc.com https://*.mobiledrivetech.com https://*.fihmb.com
https://*.bharafih.com; media-src 'self'; font-src 'self'; connect-src 'self' wss://*.fihtdc.com
ws://*.fihtdc.com wss://*.mobiledrivetech.com ws://*.mobiledrivetech.com https://*.foxconn.com
https://*.fihtdc.com https://*.mobiledrivetech.com https://*.fihmb.com https://*.bharafih.com; form-
action 'self' https://*.foxconn.com https://*.fihtdc.com https://*.mobiledrivetech.com
https://*.fihmb.com https://*.bharafih.com; frame-ancestors 'self' https://*.foxconn.com
https://*.fihtdc.com https://*.mobiledrivetech.com https://*.fihmb.com https://*.bharafih.com; frame-
src 'self' https://*.foxconn.com https://*.fihtdc.com https://*.mobiledrivetech.com https://*.fihmb.com
https://*.bharafih.com; child-src 'self'; base-uri 'self'; worker-src 'self' blob:;
```



# 感謝您！


段會峰

560-76731

peak.hf.duan@fih-foxconn.com

FIH 資訊資源處